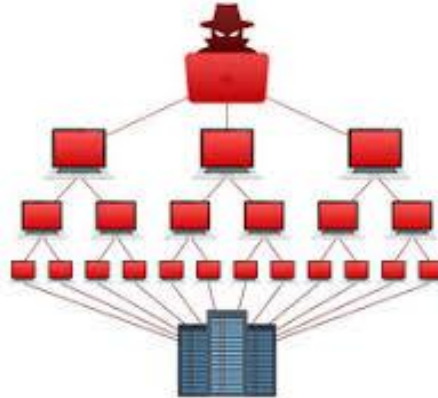


DOS and DDOS attacks



Prepared by: Siddarth B, Vishnu and Sagar Dana.

Reviewed by: Sulabh Mishra.

INTRODUCTION

DOS Attacks (Denial of Service Attacks) have become very common amongst hackers who use them as a path to fame and respect in the underground groups of the Internet. Denial of Service Attacks basically means denying valid Internet and Network users from using the services of the target network or server. It basically means, launching an attack, which will temporarily make the services, offered by the Network unusable by legitimate users. In others words, a DOS attack is one in which you clog up so much memory on the target system that it cannot serve legitimate users. Or you send the target system data packets, which cannot be handled by it and thus causes it to either crash; reboot or more commonly deny services to legitimate users.

Signs of a DoS attack



Degradation in network performance

Especially when attempting to open files stored on the network or when accessing websites.



Specific website unavailable

A particular site does not open or cannot be found.



Inability to access any website

All websites are inaccessible on the network.



High volume of email spam

A higher than usual volume of spam email.

DOS Attack



A denial-of-service (DOS) attack is a cyber attack on devices, information systems, or other network resources that prevents legitimate users from accessing expected services and resources. This is usually accomplished by flooding the targeted host or network with traffic until the target can't respond or crashes. DOS attacks can last anywhere from a few hours to many months and can cost companies time and money while their resources and services are unavailable.

In a DOS attack, the cyber attackers typically use one Internet connection and one device to send rapid and continuous requests to a target server to overload the server's bandwidth. DOS attackers exploit a software vulnerability in the system and proceed to exhaust the RAM or CPU of the server.

The damage in loss of service a DOS attack does can be fixed in a short time by implementing a firewall with allow/deny rules. Because a DOS attack only has one IP address, the IP address can be easily fished out and denied further access using a firewall. However, there is a type of DOS attack that is not so easy to detect—a distributed denial-of-service (DDOS) attack.

DDOS Attack

DDOS (Distributed Denial of Service) is a cyber attack on a specific server or network with the intended purpose of disrupting that network or server's normal operation unavailable by overloading it with vast floods of internet traffic generated from multiple sources. DDOS attacks typically use other computers and devices that are infected with malware to launch the attack.

Generally these attacks work by drowning a system with request for data. This could be sending a web server so many requests to serve a page that it crashes under the demand or it could be a database being hit with high volume of queries. The result is available internet bandwidth, CPU and RAM capacity become overwhelmed. The impact could range from minor annoyance from disrupted services to experiencing entire websites, applications or even entire businesses taking offline.

These attacks are launched using machines in a **botnet**. By distributing the malwares over internet, attackers gain access to the computers without being detected. This army of recruited vulnerable computers is termed as **botnet**. (In simple words, botnet is a group of compromised systems).

Aim of DDOS Attacks

1. Competitive advantages against rival business.
2. Ransom demands for releasing the data.
3. Activist behavior for protests and upstaging.

❖ How does the attacker gets other computers to get involved in DDOS attack?

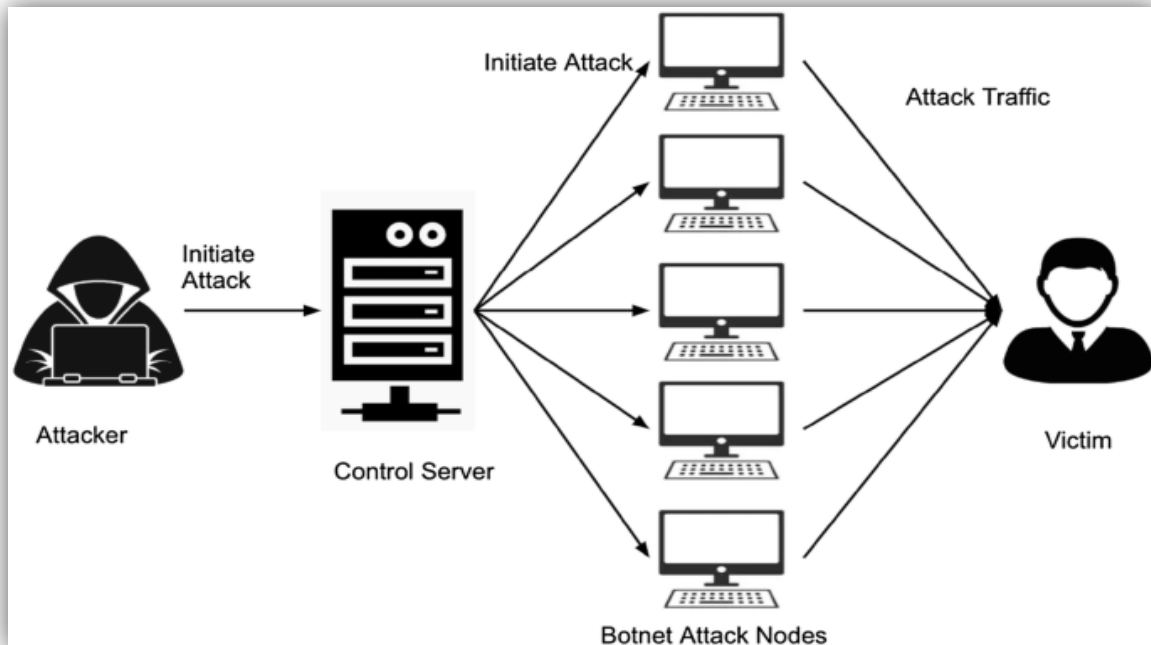
→ Attacker will develop a malware program and distribute it over the internet by putting it on websites and email attachments. So if a vulnerable computer goes to these infected websites or opens these infected email attachments, the malware will be installed on their computer and without even knowing about it they will be recruited for performing a DDOS attack with the other set of vulnerable computers. (This army of recruited computers is termed as botnet).

The Ring leader will coordinate this attack by providing commands over the botnet and web service will be compromised within just few minutes.

Symptoms of DDOS attack

- Slow access to files, either locally or remotely.
- Inability to access a particular website for long time.
- Internet disconnection.
- Problems in accessing all websites.
- Excessive amount of spam emails.

How does DDOS attack work?



DDOS attack is a two-phase process.

In the first phase a hacker creates a botnet of devices. A network of computers is hacked via malware or ransomware. These devices become a part of the botnet which can be triggered anytime to start bombarding a system or a server on instruction of the hacker that created the botnet. The devices in this network are called bots or zombies.

In the second phase a particular target is selected for the attack. When the hackers find the right time to attack all the zombies in the botnet network, send the requests to the target thereby taking up all the servers available bandwidth. These can be simple ping requests or complex attacks like SYN flooding and UDP flooding. The aim is to overwhelm them with more traffic than the

server or network can accommodate. The goal is to render the website or service inoperable.

Types of DDOS attack

1. Volumetric/Network based attacks.
2. Protocol level attack.
3. Applications level attack.

1. Volumetric/Network based attacks:

These attacks use massive amount of bogus traffic to overwhelm a resource. It can be a website or a server. They include ICMP, UDP and spoofed packet flood attacks. The size of volume based attack is measured in bits per second. These attacks focus on consuming all the bandwidth allocated to a server. A huge volume of requests are sent to the server and block all the bandwidth for regular users.

Examples: UDP floods, ICMP echo requests.

2. Protocol level attack:

These attacks are meant to consume essential resources of the target server by exhausting the load balancers and firewall which are meant to protect the system against the DDOS attacks. Layers 3 and 4 of the OSI model are compromised. The size of protocol level attack is measured in packets per seconds.

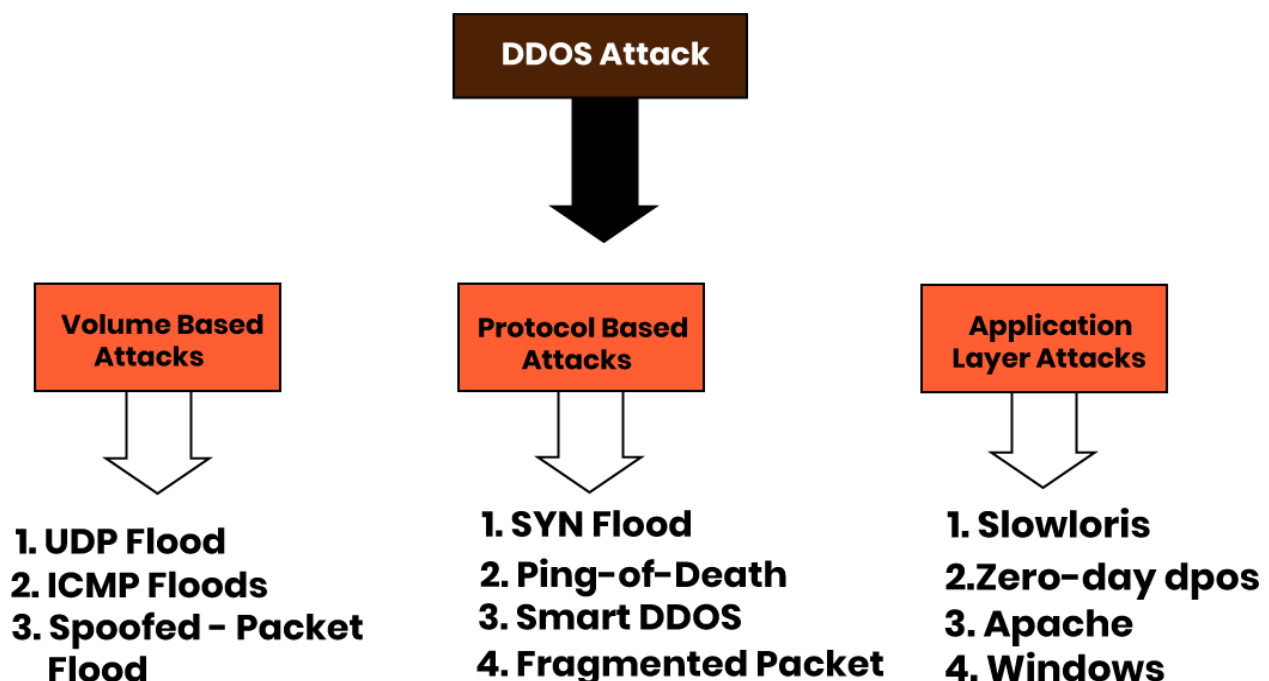
Examples: SYN Flooding, Ping of Death.

3. Application level attack:

These attacks are conducted by flooding applications with malicious requests. The size of application layer attack is measured in request per second. These are sophisticated attacks that crash the entire server by targeting application and OS level vulnerabilities. It can stop specific applications from delivering necessary information to users and hawk the network bandwidth up to the point of the system crash.

Examples: HTTP Flooding, BGP hijacking.

A single device can request data from a server using HTTP post or get without any issues. However when the requisite botnet is instructed to bombard the server with thousands of requests, the database bandwidth gets jammed and it eventually becomes unresponsive and unusable.



Mitigations:

- Deploy load balancers and firewalls – Load balancers reroute the traffic from one server to the another and Firewall blocks unwanted traffic into the system.
- Switch to cloud service providers like AWS and Azure.
- Expand bandwidth capacity to prevent clogging of data.
- Limit the number of connections from an IP or user.
- Reduce the connection waiting time.
- Use Anti-DDOS technology.